Draft Stoquify X1 Automation Delegation Policy Pack

Date: 2026-08-31
Version: 1.0-draft
Status: `DRAFT_UNSIGNED`
Effect: None until approved, signed, hash-bound, registered and activated by the named authorities

Important status notice

No executed, signed X1 policy was found that currently delegates product, security or release authority to automation. Existing Stoquify governance material requires independent release authority, separates application roles from decision authority, requires approvals to bind exact artifact hashes, and rejects single-team self-certification.

This policy pack is a review-ready draft. It does not approve the X1 budgets, authorize credentials, release X1, grant production access or create certification. The automation must reject this pack while its status is `DRAFT_UNSIGNED`.

Governing principles carried into this draft

1. Identity identifies the user or service principal.
2. An application role grants application permissions but does not create decision authority.
3. Authority must be formally appointed or delegated for an exact tenant, scope and time period.
4. Approval must be a deliberate approve or reject decision on exact hash-bound content.
5. Evidence producers cannot self-certify their own work.
6. Material artifact, policy, code, fixture or scope changes invalidate affected approvals.
7. Delegation must be bounded, time-limited, auditable and immediately revocable.
8. Tenant isolation, unauthorized access, false completion and financial-truth failures are non-waivable.
9. Automation may assemble and validate evidence but may not claim legal, accounting, security, accessibility or production certification.
10. Final production authorization remains with the independent enterprise release authority.

Policy pack objective

When all three policies below are properly completed and signed, Stoquify may run the X1 finance/accounting technical evidence workflow without interactive intervention. The automation may advance the bounded X1 technical gate only when every deterministic condition passes and the signed delegation remains valid.

This pack does not authorize production deployment. It authorizes only the specific X1 technical evidence and internal promotion workflow described below.

Common scope

Field	Draft value
Program	X1 finance/accounting table harmonization
Table contract version	Current X1 contract, hash to be recorded at signature
Budget contract version	`1`
Environment	Non-production only
Candidate database	`stoquify_replay_next_20260830`
Authorized fixture tenant candidate	`rds_org_001`
Foreign isolation-probe tenant candidate	`rds_org_002`
Required persona	`external_accountant`
Candidate persona	Carine Manga
Candidate user ID	`rds_org_001_compliance_user_external_accountant`
Required routes	Seven canonical X1 routes
Required matrix	EN/FR x desktop/tablet/mobile x seven routes
Required artifacts	42 screenshots plus fragments, manifest and validation report
Production authority	Explicitly excluded

Before signature, each candidate value must be reconfirmed from authoritative current state and replaced with the approved value if different.

Policy 1: X1 Product Performance Budget Standing Approval and Automation Delegation

Policy ID: `STOQ-X1-POL-001`
Status: `DRAFT_UNSIGNED`

Purpose

This policy records the product authority's decision on X1 engineering performance budgets and delegates deterministic evaluation of those budgets to the X1 automation service for a bounded period.

Proposed budgets subject to decision

Signal	Proposed threshold
Local sort/filter on bounded client data	Under 100 ms on p75 test hardware

Signal	Proposed threshold
Server loading indication	Under 150 ms
Server useful result	Under 1,000 ms at p75
Page navigation	Useful rows under 750 ms at p75 after cached shell
Bulk-action acknowledgement	Immediate job receipt with progress and partial-result handling
Preference/view hydration	No visible column-layout flash after the initial shell
Browser row DOM	Bounded by pagination or a proven virtualization strategy
Export duration	Measured and retained by result tier and format

These are engineering budgets and are not customer-facing service-level agreements.

Draft policy statement

The authorized product approver approves budget contract version 1 for the bounded X1 non-production evidence workflow. The automation service may evaluate measured evidence against these thresholds and may mark the budget condition passed only when all required measurements are present, current, attributable to the approved run and within the approved thresholds.

Delegated automation actions

- Read the signed policy record and validate its signature, content hash, scope, effective dates and revocation status.
- Collect performance measurements from the approved Playwright run.
- Compare measurements to budget contract version 1.
- Record pass or fail for each signal.
- Block X1 promotion if any mandatory signal fails or is missing.
- Create a remediation record automatically.

Actions not delegated

- Changing thresholds.
- Treating the budgets as contractual SLAs.
- Waiving a failed threshold.
- Approving a different contract version.
- Authorizing production deployment.
- Certifying accessibility, security, accounting or legal compliance.

Mandatory activation fields

Field	Required completion
Product approver name	`[TO BE COMPLETED]`

Field	Required completion
Product approver user ID	Candidate: `rds_org_001_compliance_user_product_approver`
Authority appointment reference	`[TO BE COMPLETED]`
Decision	`APPROVE` or `REJECT`
Effective from	`[TO BE COMPLETED]`
Expires at	`[TO BE COMPLETED]`
Contract artifact path	`[TO BE COMPLETED]`
Contract SHA-256	`[TO BE COMPLETED]`
Policy SHA-256	Generated after final text is frozen
Signature reference	`[TO BE COMPLETED]`
Approval-system record ID	`[TO BE COMPLETED]`

Recommended validity

Recommended maximum validity is 90 days or until any material X1 contract, route, fixture, performance target or measurement-method change, whichever occurs first.

Required signer

Executive product sponsor or formally appointed product approver for the X1 scope.

Policy 2: X1 Non-Production Credential, Tenant and Authenticated Evidence Delegation

Policy ID: `STOQ-X1-POL-002`
Status: `DRAFT_UNSIGNED`

Purpose

This policy authorizes a named automation service principal to obtain a bounded credential from the approved secret manager, create ephemeral browser authentication state and run the read-only X1 evidence matrix against the approved non-production environment.

Draft policy statement

The security/control owner and managed-secrets owner authorize the named automation service principal to use the approved external-accountant credential only for the exact X1 run scope, authorized tenant, approved

non-production origin and validity period. The credential and browser state remain secret, ephemeral and excluded from evidence artifacts.

Delegated automation actions

- Retrieve the approved credential using workload identity.
- Authenticate as the approved `external_accountant` persona.
- Verify the authenticated user ID, tenant ID and role.
- Create temporary Playwright storage state.
- Run read-only browser checks against the approved routes.
- Issue a read-only tenant-override probe using the approved foreign fixture tenant.
- Generate screenshots and structural measurements.
- Scan artifacts for secrets.
- Delete credential material and storage state after success, failure, cancellation or timeout.

Required security constraints

- Environment must be non-production.
- Target origin must match the signed allowlist exactly.
- Authorized tenant and foreign probe tenant must be distinct.
- The service principal must have no database-write, migration or seed authority.
- The external-accountant account must lack mutation permissions.
- Credentials must never appear in logs, manifests, screenshots, reports or command arguments.
- Storage state must never be uploaded as evidence.
- Trace and video capture remain disabled unless separately approved and sanitized.
- Artifact upload is prohibited until secret scanning passes.
- Every secret access and browser run must emit an audit event.

Actions not delegated

- Production authentication.
- Credential disclosure to an agent or operator.
- Changing user roles or permissions.
- Adding module entitlements.
- Seeding, resetting or migrating the database.
- Performing finance or accounting mutations.
- Reusing the credential outside the approved run.
- Disabling redaction, RBAC or tenant isolation.

Mandatory activation fields

Field	Required completion
Security/control owner name	Candidate: Yonga Springfield; reconfirm required

Field	Required completion
Security/control owner user ID	`[TO BE COMPLETED]`
Security authority appointment reference	`[TO BE COMPLETED]`
Managed-secrets owner	`[TO BE COMPLETED]`
Automation service-principal ID	`[TO BE COMPLETED]`
Secret-manager provider	`[TO BE COMPLETED]`
Secret reference	`[TO BE COMPLETED; never secret value]`
Approved target origin	`[TO BE COMPLETED]`
Authorized tenant	Candidate: `rds_org_001`
Foreign probe tenant	Candidate: `rds_org_002`
Approved persona user ID	Candidate: `rds_org_001_compliance_user_external_accountant`
Seeded-data approval reference	`[TO BE COMPLETED]`
Retention policy reference	`[TO BE COMPLETED]`
Effective from	`[TO BE COMPLETED]`
Expires at	`[TO BE COMPLETED]`
Policy SHA-256	Generated after final text is frozen
Security signature reference	`[TO BE COMPLETED]`
Managed-secrets signature reference	`[TO BE COMPLETED]`

Required signers

Application-security authority, security/control owner, managed-secrets owner and fixture-data/tenant owner.

Policy 3: X1 Automated Technical Evidence Review and Gate Promotion Delegation

Policy ID: `STOQ-X1-POL-003`
Status: `DRAFT_UNSIGNED`

Purpose

This policy delegates a narrowly defined internal X1 technical promotion decision to an independent automation verifier after all product and security delegations are valid.

Authority boundary

This policy may authorize the transition from X1 evidence collection to `X1_TECHNICAL_GATE_PASSED`. It may not grant `PILOT_AUTHORIZED` or `PRODUCTION_AUTHORIZED`, deploy code, certify statutory/accounting conclusions or accept residual risk outside the listed deterministic criteria.

Draft policy statement

The independent release authority authorizes the designated evidence-verifier service to mark the internal X1 technical gate passed only when every mandatory criterion below is proven by current, hash-bound evidence. Any missing, failed, stale, revoked or inconsistent condition results in `RELEASE_GATE_BLOCKED`.

Mandatory pass criteria

Criterion	Required result
Policies 1 and 2	Active, signed, unexpired, unrevoked and hash-valid
Approval scope	Exact X1 contract version, tenant, persona and run
Focused tests	All required suites pass on the current commit
Playwright matrix	42 of 42 authenticated checks pass
Required locales	English and French complete
Required viewports	Desktop, tablet and mobile complete
Required routes	Seven canonical routes complete
Persona	Exact `external_accountant` role and approved user ID
Tenant	Exact authorized tenant
Isolation probe	Foreign tenant cannot override authenticated tenant context
Mutation permissions	All forbidden permissions absent
Protected actions	No prohibited mutation action exposed
Accessibility	Zero serious or critical Axe violations
Keyboard	Visible focus demonstrated on every required surface
Layout	No document overflow or clipped required controls
Redaction	Approved redaction checks pass
Artifact scanning	No credential, token, cookie, storage state or secret-like finding
Evidence manifest	Schema-valid and complete
Artifact integrity	SHA-256 manifest complete and verified
Evidence freshness	Current commit, fixture version and workflow version
Cleanup	Temporary credential and storage state deletion confirmed

Criterion	Required result
Audit trail	Complete state transitions and service identities recorded
Performance budgets	All approved mandatory signals pass or are explicitly classified as measurement-only by Policy 1

Independence controls

- The evidence-verifier service identity must differ from the implementation and capture service identity.
- The verifier must recompute artifact hashes from immutable bytes.
- The verifier must not modify source code, tests, captured artifacts or approval records during review.
- A failed condition cannot be waived by the verifier.
- Any policy or artifact drift invalidates the promotion result.
- Periodic independent human sampling remains required under the enterprise assurance schedule.

Actions not delegated

- Production deployment or authorization.
- Pilot authorization.
- Acceptance of residual risk.
- Waiver of tenant, authorization, financial-truth or serious accessibility failures.
- Legal, statutory, accounting, security or accessibility certification.
- Changing evidence after capture.

Mandatory activation fields

Field	Required completion
Independent release authority name	`[TO BE COMPLETED]`
Independent release authority user ID	`[TO BE COMPLETED]`
Authority appointment reference	`[TO BE COMPLETED]`
Evidence-verifier service-principal ID	`[TO BE COMPLETED]`
Evidence-store reference	`[TO BE COMPLETED]`
Retention policy reference	`[TO BE COMPLETED]`
Current commit binding rule	`[TO BE COMPLETED]`
Fixture-version binding rule	`[TO BE COMPLETED]`
Effective from	`[TO BE COMPLETED]`
Expires at	`[TO BE COMPLETED]`
Policy SHA-256	Generated after final text is frozen
Release-authority signature reference	`[TO BE COMPLETED]`

Required signer

Named independent enterprise release authority. Supporting concurrence from product, security/control and finance/control owners is recommended and may be required by the organization's governance charter.

Combined activation rule

The X1 unattended workflow may activate only when:

```
Policy 1 status = ACTIVE_SIGNED
AND Policy 2 status = ACTIVE_SIGNED
AND Policy 3 status = ACTIVE_SIGNED
AND every policy signature is valid
AND every policy hash matches immutable content
AND all effective dates include the run time
AND no policy or appointment is revoked
AND the run scope matches every policy exactly
```

Any other state must produce `AWAITING_AUTHORITY` or `RELEASE_GATE_BLOCKED`.

Policy lifecycle and revocation

Every policy must support:

- `DRAFT_UNSIGNED`
- `PENDING_APPROVAL`
- `ACTIVE_SIGNED`
- `SUSPENDED`
- `EXPIRED`
- `REVOKED`
- `SUPERSEDED`

Revocation must immediately stop new runs, invalidate unconsumed approvals, terminate active credential leases where technically possible and emit an audited event.

Material changes requiring reapproval include:

- X1 contract version change.
- Budget threshold or measurement-method change.
- Route, locale or viewport matrix change.
- Tenant, persona or credential change.
- RBAC, entitlement or redaction-policy change.
- Secret-manager or service-principal change.
- Evidence-store or retention-policy change.
- Verifier implementation change affecting decision logic.
- Material finance/accounting workflow change.

Segregation of duties

Activity	Required authority
Implement code	Engineering identity
Approve product budgets	Product authority
Authorize credential and tenant use	Security/control and secrets authority
Capture evidence	Capture service identity
Verify evidence and hashes	Independent verifier identity
Approve production	Independent enterprise release authority outside this pack

The same service identity must not implement, capture and verify the same X1 release candidate.

Signature and registration page

This section must be completed in the authoritative approval system. Typed names in this draft are not signatures.

Policy	Decision	Approver	User ID	Authority reference	Signed at	Signature reference	Content SHA-256
`STOQ-X1-POL-001`	`[ ] Approve [ ] Reject`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`
`STOQ-X1-POL-002`	`[ ] Approve [ ] Reject`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`
`STOQ-X1-POL-003`	`[ ] Approve [ ] Reject`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`	`[TO BE COMPLETED]`

Adoption procedure

1. Confirm the organization's legal entity and governance charter that may issue these delegations.
2. Name the product, security/control, managed-secrets, fixture-data and independent release authorities.
3. Confirm the exact service-principal identities for orchestration, capture and independent verification.
4. Confirm the non-production origin, tenants, persona, secret reference, evidence store and retention policy.
5. Freeze this policy text and the referenced X1 contract artifacts.
6. Compute SHA-256 hashes for every frozen artifact and policy.
7. Submit the three policies through the authoritative approval system.
8. Require fresh authentication and explicit approve or reject intent from each signer.

9. Store signature references, timestamps, authority references and hashes in immutable policy records.
10. Register the policy records in the Stoquify control plane as `ACTIVE_SIGNED` only after independent signature verification.
11. Test rejection, expiry, revocation, hash drift, provider outage and service-identity mismatch before enabling unattended execution.
12. Keep `PILOT_AUTHORIZED` and `PRODUCTION_AUTHORIZED` outside this policy pack.

Minimum independent review before activation

The governance or assurance reviewer must confirm:

- Every signer has formal authority for the stated scope.
- No signer is relying only on an application role.
- The content hashes bind the exact approved text and artifacts.
- The service principals are least-privileged and segregated.
- Secret retrieval is auditable and ephemeral.
- Evidence storage is immutable and retention-controlled.
- Revocation is immediate and tested.
- The automation fails closed.
- Production release remains outside the delegated X1 technical gate.

References

- `docs/UI-UX-remediation/06_PHASE_GATES_AND_RELEASE_CRITERIA.md`
- `docs/UI-UX-remediation/08_RISK_ASSUMPTION_DECISION_LOG.md`
- `docs/blockers-and-gates/BLOCKER_GATE_CONTROL_PLANE_PLAIN_LANGUAGE_GUIDE_2026-08-18.md`
- `docs/blockers-and-gates/cameroon-hris-payroll-authority/CAMEROON_EMPLOYMENT_DOCUMENT_REQUIREMENTS_MATRIX_2026-08-19.md`
- `docs/gates-and-blockers/STOQUIFY_PRODUCTION_UNBLOCKING_EXECUTION_ROADMAP_2026-08-22.md`
- `docs/credentials-blockers/STOQUIFY_X1_FINANCE_CREDENTIALS_AND_BLOCKER_UNBLOCK_REPORT_2026-08-31.md`

Final draft disposition

Status remains `DRAFT_UNSIGNED`. This document becomes operative only after all mandatory fields are completed, the exact content is frozen and hashed, the required authorities approve it through an authoritative system, signatures are independently verified and the three machine-readable policy records are activated.